

ГЕНЕРАЦИЯ МНОЖЕСТВА ВОЗМОЖНЫХ СЦЕНАРИЕВ РЕАЛИЗАЦИИ КОМПЬЮТЕРНЫХ АТАК

А.А. Остапенко, С.В. Краснопольский, М.М. Скрипкин, А.В. Ясенов

В статье рассматривается подход к генерации и визуализации сценариев компьютерных атак на защищаемые объекты, являющиеся компонентами автоматизированных информационных систем, и предлагается программная реализация данного подхода. В рамках подхода предоставляется методика реализации моделирования сценариев эксплуатации уязвимостей по отношению к защищаемым объектам для противодействия современным компьютерным атакам. Актуальность информации, поступающей на вход программного модуля, обеспечивается использованием агрегированных данных из баз знаний MITRE ATT&CK, CAPEC, CWE, NVD, EPSS и CISA KEV. Предложены алгоритм генерации сценариев компьютерных атак и алгоритм их ранжирования, решающий проблему «комбинаторного взрыва» и позволяющий выбрать сценарии с наибольшим показателем риска при приемлемой нагрузке на аппаратное обеспечение.

Ключевые слова: генерация, моделирование, сценарий, уязвимости, шаблоны атак, тактики, техники, компьютерные атаки.

Введение

В условиях стремительного возрастания количества и повышения сложности компьютерных атак на автоматизированные информационные системы (далее — АИС), а также увеличения их масштаба организация технической защиты АИС объективно требует новых подходов к моделированию и прогнозированию векторов возможных атак. Современные информационные системы и инфраструктуры становятся всё более комплексными, распределёнными и гетерогенными, что затрудняет моделирование компьютерных атак по отношению к ним и одновременно с этим кратно увеличивает объём уязвимостей в АИС и количество возможных векторов для проведения атак [1].

Специалистам по информационной безопасности, обеспечивающим защиту АИС от внешних и внутренних угроз, приходится иметь дело с десятками объектов, подлежащих защите, сотнями уязвимостей и тысячами возможных сценариев проведения атак на упомянутые объекты. В связи с этим в настоящей работе предлагается подход к генерации возможных сценариев компьютерных атак, направленных на конкретные компоненты защищаемых АИС, и реализация этого подхода в

соответствующем программном обеспечении, что определённо будет иметь практическую ценность для инженеров по защите информации [1-5].

Объектом данного исследования являются АИС, рассматриваемые в контексте функционирования в условиях целенаправленных компьютерных атак.

Предметом исследования являются методики и алгоритмы автоматизированной генерации сценариев компьютерных атак на защищаемые объекты, входящие в состав вышеупомянутых систем.

Актуальность настоящего исследования обусловлена наличием следующих противоречий между:

1) объективной потребностью в агрегации информации об уязвимостях, типах ошибок программного обеспечения, шаблонах кибератак, техниках и тактиках MITRE ATT&CK в единую базу знаний со своевременным обновлением данных и минимальной латентностью и разрозненным хранением упомянутых данных в различных источниках;

2) необходимостью анализа сценариев кибератак на компоненты защищаемых систем для принятия решений в рамках процесса управления рисками ИБ и отсутствием программных комплексов,

позволяющих формировать, визуализировать и анализировать сценарии кибератак на конкретные защищаемые объекты АИС.

Цель работы заключается в повышении качества процесса управления рисками за счет разработки программного обеспечения для автоматизированной генерации и визуализации сценариев кибератак на защищаемые объекты автоматизированных информационных систем.

Для достижения поставленной цели предстоит решить следующие задачи:

1) разработать алгоритмическое и программное обеспечение, позволяющее автоматизировать процессы сбора, хранения, обработки и обновления данных из разнородных источников и решающее проблему недостаточной связности между узлами баз данных;

2) разработать алгоритмическое и программное обеспечение для генерации и визуализации сценариев кибератак на конкретные защищаемые объекты автоматизированных информационных систем, предоставить возможности для удобного анализа сгенерированных сценариев пользователем программного обеспечения и последующей обработки результатов генерации сторонними модулями.

Новизна полученных результатов состоит в следующем:

1) в разработанном алгоритмическом и программном обеспечении для автоматизированной агрегации, обработки и хранения данных предложен новый подход для достраивания наиболее вероятных взаимосвязей между компонентами кибератак с применением графовых нейронных сетей (далее — GNN), обучающихся не только на семантических свойствах текстов, но и на структуре существующих взаимосвязей в базе данных;

2) разработанный программный модуль автоматизированной генерации сценариев кибератак впервые реализует подход, направленный на генерацию сценариев применительно к конкретным защищаемым объектам.

Теоретическая значимость полученных результатов заключается в следующем:

1) применённый в работе подход, предлагающий использование GNN для прогнозирования отсутствующих в исходных базах данных, но весьма вероятных взаимосвязей между компонентами кибератак, вносит вклад в концепцию применения GNN в предметной области информационной безопасности;

2) предложенный подход к генерации сценариев кибератак закладывает основу для дальнейших работ по автоматизации и повышению качества процесса риск-анализа за счёт перехода от рассмотрения более абстрактных сценариев, привязанных к шаблонам CAPEC, к рассмотрению более предметных сценариев кибератак, направленных на конкретные компоненты АИС.

Практическая ценность полученных результатов видится в том, что:

1) разработанное программное обеспечение для автоматизированного сбора, хранения, обработки и обновления данных, помимо создания единой актуальной базы знаний о компонентах компьютерных атак, позволяет учесть максимальное число уязвимостей защищаемого объекта за счёт применения GNN для прогнозирования связей в базе знаний, а также может быть интегрировано в любые программные модули, способные работать с графовой базой данных;

2) разработанное программное обеспечение для генерации возможных сценариев компьютерных атак на конкретные защищаемые объекты АИС представляет практический интерес для администраторов и инженеров ИБ, предлагая возможности для визуализации, анализа и экспорта полученных результатов и упрощая процесс управления рисками.

Методические основы построения мультиграфа отношений шаблонов, техник реализации компьютерных атак, типов ошибок и уязвимостей

Генерация сценариев компьютерных атак в разработанном программном модуле основана на агрегации данных из нескольких баз знаний (MITRE ATT&CK, CAPEC, CWE, NVD, FIRST и CISA KEV) [6-11] в единую базу знаний, где информация о компонентах

компьютерных атак и взаимосвязях между ними представлена в виде ориентированного мультиграфа:

$$G = (N, E), \quad (1)$$

где N — множество узлов графа (компонентов атак),

E — множество его дуг.

Множество N включает в себя следующие элементы:

1) техники компьютерных атак из базы знаний MITRE ATT&CK;

2) шаблоны атак из базы знаний CAPEC;

3) типы ошибок программного обеспечения из базы знаний CWE;

4) уязвимости программного обеспечения из базы знаний CVE;

5) защищаемые объекты CPE, по отношению к которым возможна эксплуатация уязвимостей.

Множество дуг E включает в себя связи между парами узлов, перечисленными ниже. Приоритетным источником получения информации о взаимосвязях между компонентами атак являются упомянутые ранее ресурсы [6-9], но при необходимости пользователь программного модуля имеет возможность задействовать GNN для повышения связности узлов в графе. Далее в скобках будем приводить название связи, под которым она существует в графовой базе данных и которое отражает направление соответствующих дуг:

1) шаблоны и техники компьютерных атак (CAPEC_TO_TECHNIQUE, CAPEC_TO_TECHNIQUE_PRED);

2) родительские и дочерние шаблоны компьютерных атак (CAPEC_PARENT_TO_CAPEC_CHILD);

3) шаблоны и типы ошибок программного обеспечения (CAPEC_TO_CWE);

4) типы ошибок программного обеспечения и уязвимости (CWE_TO_CVE);

5) уязвимости и объекты CPE (CVE_TO_CPE).

В качестве графовой базы данных для долговременного хранения всей собранной информации в виде ориентированного графа было выбрано программное обеспечение

Neo4j ввиду широкой поддержки работы с графами, наличия собственного языка запросов и удобства разворачивания с применением технологий контейнеризации [12].

Также стоит подробнее рассмотреть объекты CPE, использующиеся в программном комплексе для обозначения и классификации компонентов защищаемых АИС, по отношению к которым рассматриваются сценарии компьютерных атак. Данная аббревиатура расшифровывается как Common Platform Enumeration и представляет собой унифицированный машиночитаемый стандарт именования программных и аппаратных продуктов, затронутых конкретными уязвимостями. Информация о CPE и связанных с ними уязвимостях представлена в базе знаний NVD (National Vulnerability Database, Национальная база данных уязвимостей США) [9], созданной и поддерживаемой Национальным институтом стандартов и технологий (NIST) США. На текущий момент актуальным форматом CPE является CPE 2.3, выглядящий следующим образом:

cpe:2.3:<part>:<vendor>:<product>:<version>:<update>:<edition>:<language>:<sw_edition>:<target_sw>:<target_hw>:<other>, где

1) part — тип объекта: *a* (программное обеспечение, application), *o* (операционная система, operating system) или *h* (аппаратное обеспечение, hardware);

2) vendor — производитель продукта;

3) product — наименование продукта;

4) version — версия продукта;

5) update — номер обновления либо патча;

6) edition — редакция продукта (поле было признано устаревшим в версии CPE 2.3 и оставлено для совместимости с более старыми версиями стандарта);

7) language — язык, поддерживаемый графическим интерфейсом продукта в соответствии со спецификацией RFC5646;

8) `sw_edition` — публичное наименование редакции продукта, например, `online edition` или `common edition`;

9) `target_sw` — целевое программное обеспечение, необходимое для работы продукта;

10) `target_hw` — целевая платформа, для которой разработан продукт;

11) `other` — прочие дополнительные атрибуты, специфичные для конкретного вендора или продукта.

Большинство программных и аппаратных продуктов, для которых присутствует идентификатор CPE, не имеют всех заполненных полей. Для таких случаев в записях идентификаторов CPE используются соответствующие нотации. Символ астериск «*» означает «любой» и используется, когда отсутствуют ограничения на приемлемые

значения для данного атрибута (например, данный символ в поле `version` будет означать, что идентификатор CPE подходит для всех версий продукта). Также вместо астериска значение для атрибута может отсутствовать вовсе, эти записи являются эквивалентными. Дефис, или же прочерк означает «неприменимо» и может проставляться в случаях, когда данный атрибут не используется для описания продукта [13].

В качестве примера рассмотрим следующую запись идентификатора CPE 2.3:

`cpe:2.3:a:openssl:openssl:3.3.1:::*:*`,

которая эквивалентна

`cpe:2.3:a:openssl:openssl:3.3.1:*:*:*:*:*`.

Описание полей приведённого

идентификатора представлено в табл. 1:

Таблица 1

Описание полей идентификатора CPE OpenSSL

Атрибут	Значение	Описание
<code>part</code>	<code>a</code>	Программное обеспечение (в отличие от операционной системы <code>o</code> или от аппаратного обеспечения <code>h</code>).
<code>vendor</code>	<code>openssl</code>	Наименование производителя ПО, аппаратного продукта или ОС. Для <code>open-source</code> продуктов для этого атрибута ставится значение из поля <code>product</code> .
<code>product</code>	<code>openssl</code>	Наименование продукта, в данном случае — <code>openssl</code> , криптографическая библиотека с открытым исходным кодом, реализующая протоколы <code>SSL/TLS</code> .
<code>version</code>	<code>3.3.1</code>	Версия продукта. Для этого атрибута также может встречаться значение <code>*</code> .
<code>update</code>	<code>*</code>	Конкретный номер обновления или патча не указан, соответственно, описание CPE применимо к <code>openssl</code> версии 3.3.1 и любым номером патча.
<code>edition, language, sw_edition, target_sw, target_hw, other</code>	<code>*</code>	Для данных атрибутов конкретные значения также не определены.

Однако не во всех ситуациях выбор CPE в качестве защищаемого объекта и отправной точки для генерации множества сценариев атак в отношении него оправдан с практической точки зрения. Для устранения этого недостатка была реализована интеграция разработанного программного обеспечения со сканерами уязвимостей,

позволяющая загрузить отчёт о сканировании в формате XML, из которого будет извлечена информация об обнаруженных в процессе сканирования уязвимостях. Формат XML для создаваемых отчётов о ходе сканирования поддерживается как для популярного сканера уязвимостей `OpenVAS`, так и для многих отечественных решений, в том числе

MaxPatrol VM, Xspider и Сканер-ВС. Соответственно, инженеры по защите информации будут иметь возможность использовать разработанное программное обеспечение для генерации, визуализации и риск-анализа сценариев атак на объекты, в отношении которых было произведено сканирование любым из вышеперечисленных средств.

Таким образом, графовая база данных программного модуля объединяет сведения из MITRE ATT&CK, CAPEC, CWE, NVD, FIRST и CISA KEV. Принцип работы модуля заключается в поиске в агрегированном графе всех возможных путей от целевого защищаемого объекта до используемых злоумышленниками техник, что позволяет построить многоэтапные сценарии эксплуатации уязвимостей, относящихся к упомянутому объекту. Алгоритмическое обеспечение данного модуля более подробно будет рассмотрено далее.

Методические основы формирования подграфов сценариев реализации компьютерных атак

Процесс выборки множества узлов из графовой базы данных для генерации сценариев компьютерных атак можно описать следующим образом.

1. Загрузка и обновление данных. Данный шаг относится к работе другого модуля, входящего в состав программного комплекса и отвечающего за агрегацию данных, однако наполнение базы знаний является необходимым шагом перед переходом к генерации сценариев. Кроме того, для выполнения модулем актуального риск-анализа перед его запуском необходимо выполнение обновления базы знаний, в частности, актуализация метрик EPSS и CISA KEV.

2. Запрос связанной информации для заданного защищаемого объекта (CPE). Пользователем программного комплекса задаётся целевой защищаемый объект, например, конкретный сервер, сетевое оборудование или приложение, идентифицируемое CPE. Далее выполняется запрос к графовой базе данных с целью собрать все доказательства осуществимости атак на заданный объект. Иными словами,

происходит обнаружение всех техник MITRE ATT&CK, для которых в графе существуют пути, связывающие их с целевым объектом через последовательность узлов: техника → CAPEC → CWE → CVE → CPE. Модуль способен выполнять поиск в трёх различных режимах:

- строгий режим поиска (и, соответственно, генерации) допускает от техники до защищаемого объекта ровно в том виде, который представлен выше, то есть в пути может присутствовать только один узел CAPEC,

- нестрогий режим допускает наличие путей следующего вида: техника → родительский шаблон CAPEC → дочерний шаблон CAPEC → CWE → CVE → CPE или техника → дочерний шаблон CAPEC → родительский шаблон CAPEC → CWE → CVE → CPE. Таким образом, помимо увеличения количества рассматриваемых техник для генерации сценариев увеличивается и рассматриваемое множество уязвимостей защищаемого объекта, поскольку не для всех из них в графе существует путь, описанный для строгого режима,

- режим GNN позволяет включать в рассмотрение связи CAPEC_TO_TECHNIQUE_PRED, то есть вероятные связи между узлами CAPEC и техник, предсказанные модулем GNN. В остальном режим аналогичен строгому, то есть путь допускает наличие ровно одного узла CAPEC.

Множество узлов, полученное в результате выполнения рассмотренных выше запросов к базе данных, служит основой для генерации сценариев атак и образует доказательную базу для каждой уязвимости защищаемого объекта и каждой техники, потенциально способной её проэксплуатировать. Программный модуль позволяет визуализировать данное множество, что продемонстрировано на рис. 1. Для наглядности визуализации в качестве защищаемого объекта был выбран контроллер сервер Airleader Master Control (cpe:2.3:o:airleader:airleader_master_control:*.:*:*:*:*:*) с небольшим количеством уязвимостей и, соответственно, возможных сценариев атак.

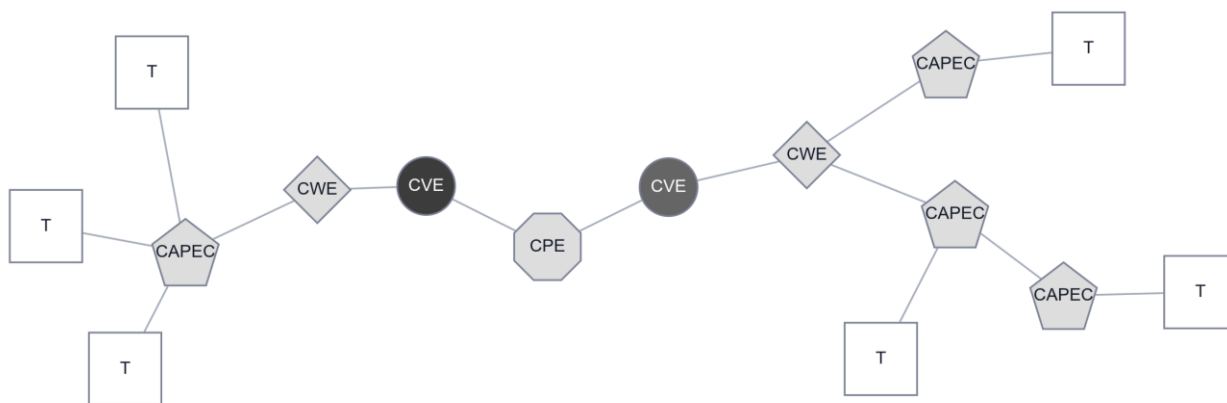


Рис.1. Множество узлов, полученное в результате выполнения запроса к базе данных

3. Обогащение результатов. После получения множества узлов из графовой базы данных производится расчёт дополнительных метрик для полученных уязвимостей. Для каждой отобранной уязвимости рассчитываются дополнительные метрики, необходимые для дальнейшего риск-анализа — вероятность эксплуатации, ущерб и риск. При расчёте указанных метрик мы полагаем, что величина EPSS оказывается пропорциональной вероятности эксплуатации уязвимости в полной группе событий, которую составляют все уязвимости, способные быть проэксплуатированными злоумышленником для достижения определённой тактической цели (например, повышения привилегий) в ходе проведения атаки, то есть эксплуатация

которых возможна в рамках рассматриваемой тактики MITRE.

Методические основы анализа рисков сформированных сценариев компьютерных атак

Метрики, полученные из базы данных во формирования подграфа сценариев компьютерных атак, позволяют осуществить дальнейшие расчёты вероятностей эксплуатации уязвимостей, ожидаемого ущерба от их реализации показателя риска для каждой уязвимости в отдельности и для каждого сценария.

Вероятность эксплуатации можно аналитически определить в следующем нормализованном виде:

$$\bar{P}(CVE_i) = \frac{P(CVE_i)}{\sum_i P(CVE_i)}, \quad (2)$$

где

$$P(CVE_i) = EPSS(CVE_i) \prod_{j=1} [1 - EPSS(CVE_j)]; \quad (3)$$

$EPSS(CVE_i)$ — метрика EPSS-ресурса для уязвимости CVE_i .

Ущерб конкретной CVE в полной группе событий представляется возможным определить с помощью метрики CVSS.

Полагая, что упомянутая метрика пропорциональна риску уязвимости, можно записать выражение для нахождения ущерба:

$$\bar{U}(CVE_i) = \frac{\frac{CVSS(CVE_i)}{EPSS(CVE_i)}}{\max_j \left[\frac{CVSS(CVE_j)}{EPSS(CVE_j)} \right]}, \quad (4)$$

где $CVSS(CVE_i)$ — значение метрики CVSS для уязвимости CVE_i .

Выражение (4) позволяет найти удельный ущерб уязвимости, нормированный по максимальному значению

ущерба среди всех уязвимостей в полной группе событий.

Ущерб в контексте всего сценария, то есть последовательности техник и связанных с ними уязвимостей, можно найти следующим образом:

$$\bar{U}(S_m) = \frac{\sum_k \frac{CVSS(CVE_{ik})}{EPSS(CVE_{ik})}}{\sum_k \max_j \left[\frac{CVSS(CVE_{jk})}{EPSS(CVE_{jk})} \right]}, \quad (5)$$

где m — индекс сценария S , выбранного из множества возможных сценариев атак на заданный защищаемый объект;

k — индекс тактики в сценарии S ;

i — индекс уязвимости, проэксплуатированной в тактике k ;

j — индекс всех уязвимостей, которые могут быть проэксплуатированы в тактике k .

Таким образом, удельный риск сценария S представляет собой отношение суммы ущербов от проэксплуатированных уязвимостей в сценарии S к сумме максимальных значений ущербов на каждом шаге (тактике) сценария.

Риск уязвимости определяется как произведение её ущерба на вероятность эксплуатации:

$$Risk(CVE_i) = \bar{P}(CVE_i) \cdot \bar{U}(CVE_i). \quad (6)$$

Риск всего сценария можно определить следующим образом:

$$Risk(S_m) = \bar{U}(S_m) \cdot \prod_i \bar{P}(CVE_{mi}). \quad (7)$$

То есть риск сценария S_m равен произведению вероятностей проэксплуатированных на всех этапах сценария уязвимостей, умноженному на ущерб, полученный от реализации сценария S_m .

В программном модуле также реализовано расщепление значения метрики CVSS на составляющие по уровню влияния на конфиденциальность, целостность и

доступность путём применения метода Шепли. С применением указанного метода становится возможным вычислить значения ущерба и, соответственно, риска относительно каждого из перечисленных свойств безопасности информации с использованием формулы (7) для риска и формул (8), (9) и (10) для ущерба:

$$\bar{U}(CVE_i) = \frac{\frac{CVSS_K(CVE_i)}{EPSS(CVE_i)}}{\max_j \left[\frac{CVSS(CVE_j)}{EPSS(CVE_j)} \right]}, \quad (8)$$

$$\bar{U}(CVE_i) = \frac{\frac{CVSS_I(CVE_i)}{EPSS(CVE_i)}}{\max_j \left[\frac{CVSS(CVE_j)}{EPSS(CVE_j)} \right]}, \quad (9)$$

$$\bar{U}(CVE_i) = \frac{\frac{CVSS_D(CVE_i)}{EPSS(CVE_i)}}{\max_j \left[\frac{CVSS(CVE_j)}{EPSS(CVE_j)} \right]}, \quad (10)$$

где $CVSS_K(CVE_i)$ — вклад свойства конфиденциальности информации в базовую оценку CVSS для уязвимости CVE_i ;

$CVSS_I(CVE_i)$ — вклад свойства целостности информации в базовую оценку CVSS для уязвимости CVE_i ;

$CVSS_D(CVE_i)$ — вклад свойства доступности информации в базовую оценку CVSS для уязвимости CVE_i .

Таким образом, на данном этапе мы получаем структурированное представление всех потенциальных шагов атаки на выбранный защищаемый объект с привязкой данных шагов к тактикам MITRE и с указанием конкретных уязвимостей, посредством которых данные шаги могут быть реализованы.

Уязвимости на каждом шаге (тактике) формируют полную группу событий, в контексте которой для них рассчитываются метрики по формулам (2), (3), (4) и (6). Формулы (5) и (7) применяются позднее для риск-анализа сгенерированных сценариев на основе заранее рассчитанных метрик уязвимостей, что позволяет ранжировать сценарии в соответствии с их показателем риска.

Алгоритмическое обеспечение генерации сценариев компьютерных атак

После получения всей необходимой информации о тактиках, техниках и

уязвимостях, релевантных для выбранного объекта СРЕ, происходит непосредственно генерация сценариев компьютерных атак. Алгоритм генерации представлен далее на блок-схеме (рис. 2):

Приведённый алгоритм генерирует множество сценариев атаки на целевой защищаемый объект, опираясь на множество узлов, полученное в результате выполнения запроса к базе данных в одном из ранее упомянутых режимов (строгом, нестрогом или GNN). Посредством данного запроса поэтапно извлекаются уязвимости CVE, связанные с рассматриваемым объектом, далее связанные с ними типы ошибок программного обеспечения CWE, затем по этим связям выявляются релевантные шаблоны CAPEC и наконец определяются связанные с ними техники. После формирования выходных данных выполненного запроса необходимо сгруппировать техники по тактикам, к которым они относятся. На этом этапе отсеиваются техники и тактики, малоподходящие для формирования сценариев, поскольку, как правило, не требуют эксплуатации уязвимостей (разведка, подготовка ресурсов).

Далее для каждой уязвимости происходит расчёт метрик по формулам (2), (3), (4) и (6). На следующем этапе мы уже имеем набор узлов, представляющий собой

множество сценариев — то есть множество соответствия с их порядком в матрице уязвимостей, связанных с техниками их MITRE ATT&СК [6].
эксплуатации, которые в свою очередь сгруппированы по тактикам, размещённым в

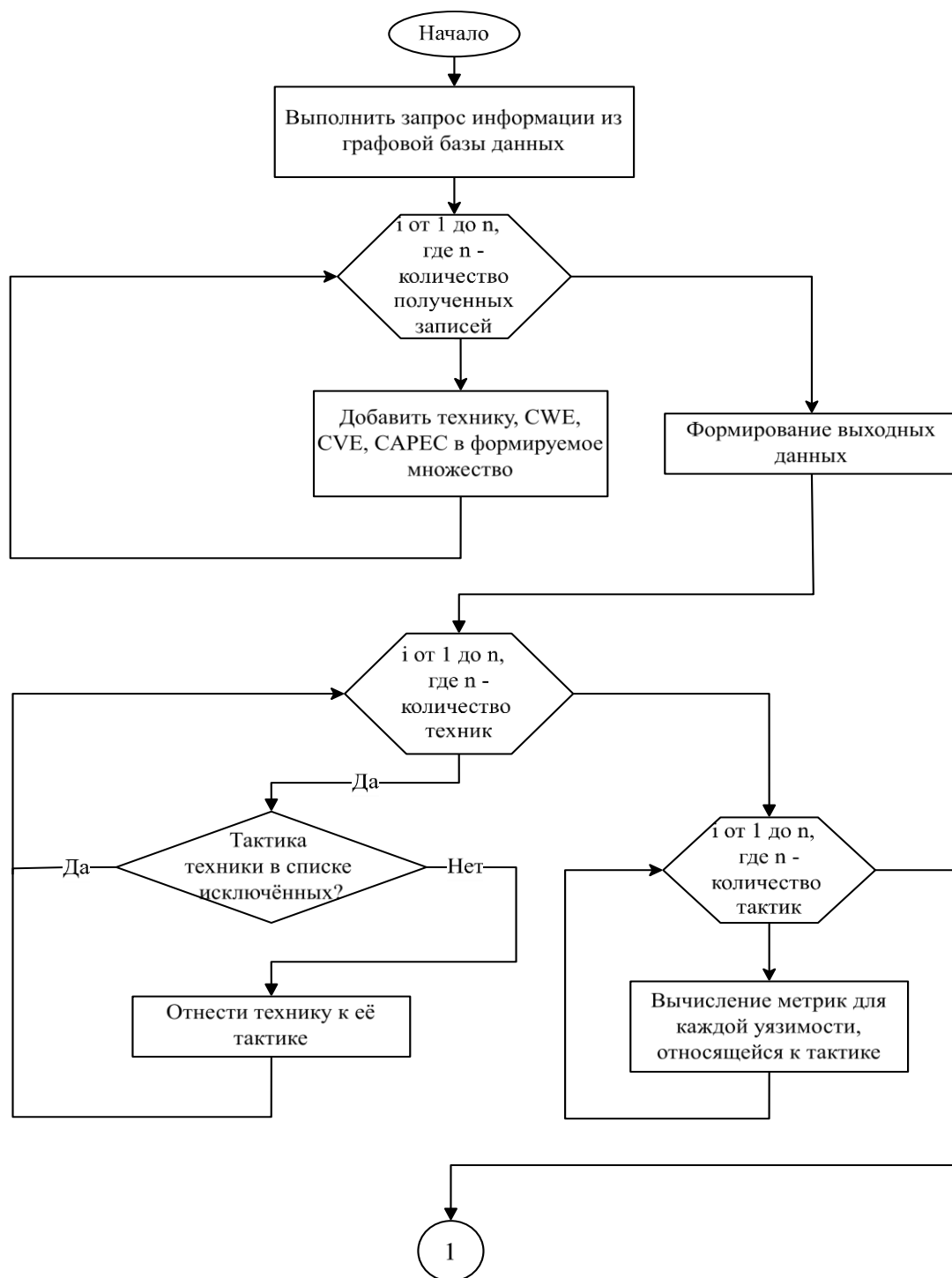


Рис. 2. Блок-схема алгоритма генерации сценариев атак

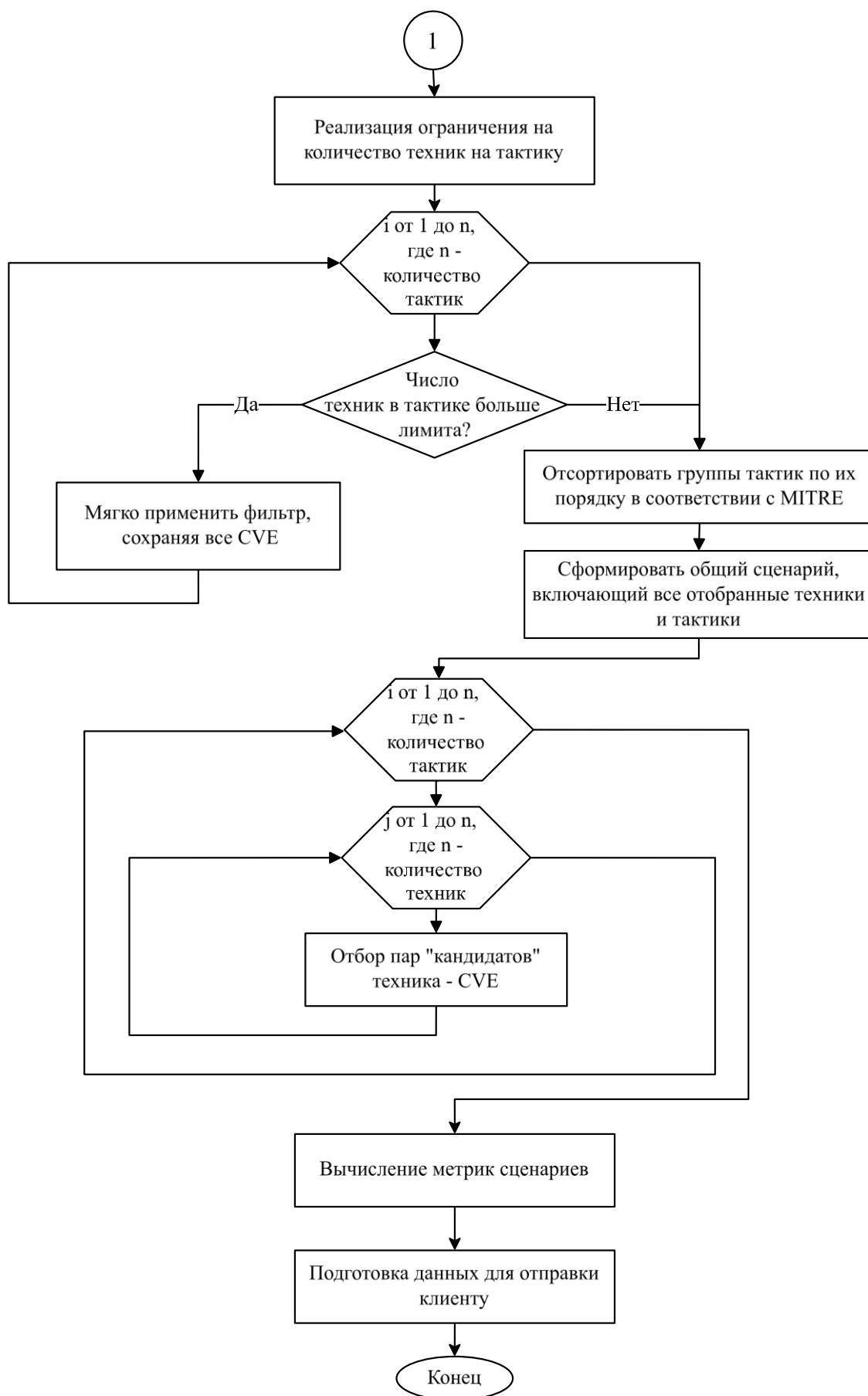


Рис. 2. Блок-схема алгоритма генерации сценариев атак (продолжение)

На этом шаге к данному множеству применяется нестрогий фильтр по ограничению количества техник на тактику, устанавливаемый пользователем программного комплекса при запуске генерации сценариев. Смысл его в том, чтобы не перегрузить сценарий лишними ветвлениями, то есть избежать ситуации, когда одна тактика может содержать, например, две уязвимости и около десяти техник, каждая из которых способна эксплуатировать обе из данных уязвимостей. В таком случае количество возможных сценариев атаккратно увеличивается, причём полученные сценарии будут различаться только техниками на одном шаге и риск-метрики сценариев также будут одинаковы. Однако, та или иная используемая злоумышленником техника эксплуатации может влиять на риск, поскольку к техникам также возможно применить превентивные меры и тем самым снизить риск конкретного сценария. Именно поэтому возможность установки упомянутого порога и определения его значения предоставлена пользователю программного комплекса, который должен руководствоваться поставленными перед ним задачами при принятии решения.

Как уже было упомянуто, фильтр реализован нестрогим образом: при любом

его значении не будет происходить усеменение множества уязвимостей, участвующих в формировании сценариев. Для каждой тактики отбирается ограниченный установленным порогом набор техник (по умолчанию — не более трёх техник на тактику) с целью полного покрытия определённых для данного шага сценария уязвимостей. Отбор реализован жадным образом — последовательно выбираются техники с максимальным покрытием уязвимостей, при необходимости превышая установленное пользователем ограничение. Допустим, если установлен лимит в три техники на тактику, а для полного покрытия необходимо четыре, будет отобрано четыре или более техник (поскольку жадный алгоритм не гарантирует оптимального решения).

В результате выполнения этих шагов формируется упорядоченный в хронологическом порядке (в соответствии с последовательностью тактик MITRE) набор шагов, где каждый шаг представляет собой тактику, содержащую несколько техник и уязвимости, которые могут быть проэксплуатированы данными техниками. Данное множество, или же «общий» сценарий, можно отобразить в следующем виде (рис. 3).

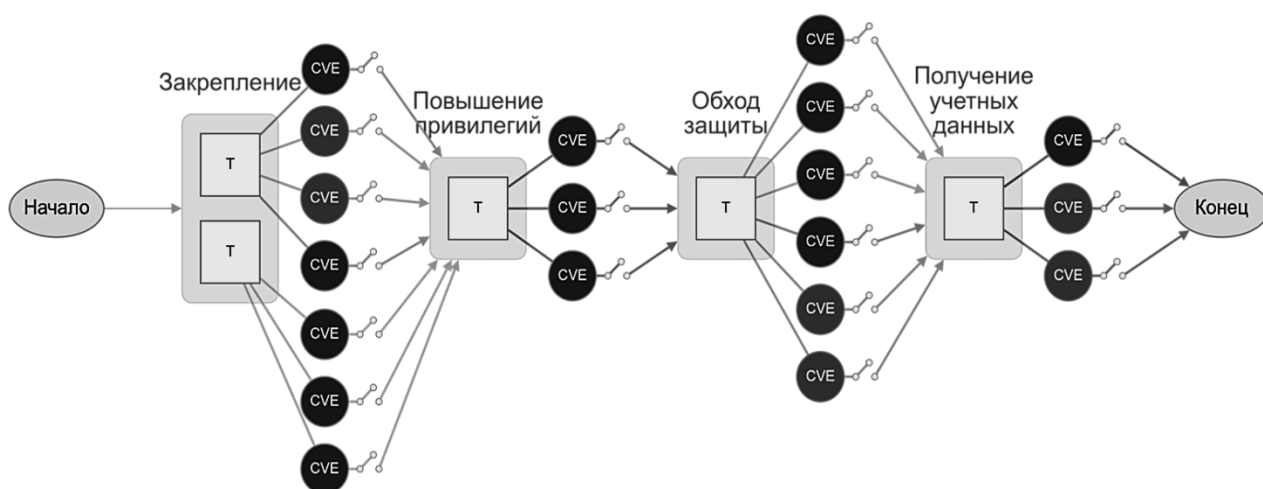


Рис. 3. Множество сценариев атаки на операционную систему Android версии 7.2
(cpe:2.3:o:google:android:7.2:*:*:*:*:*:*)

Далее из полученного множества необходимо выделить линейные сценарии атак, содержащие на каждом своём шаге ровно одну технику и одну эксплуатируемую ей уязвимость. Эта задача будет подробнее рассмотрена далее в алгоритмическом обеспечении ранжирования сгенерированных сценариев, но подготовка исходных данных для её решения осуществляется сразу после построения «общего» сценария. На данном шаге на основе полученного множества производится отбор пар техника-уязвимость по этапам сценария (тактикам): для каждой тактики генерируются варианты шагов, где фиксируется одна техника и одна соответствующая уязвимость с рассчитанными метриками. Сформированные пары сортируются и готовятся к дальнейшему ранжированию.

Алгоритмическое обеспечение ранжирования сценариев на этапе генерации в соответствии с уровнем риска

Наиболее простым, но одновременно с этим наиболее неэффективным подходом к генерации линейных сценариев, проведению их риск-анализа и ранжирования является полный перебор всех возможных вариантов. Данный подход требует значительных вычислительных ресурсов, следовательно, либо исключается возможность разворачивания и использования программного комплекса на автоматизированных рабочих местах инженеров по защите информации, либо программный комплекс не обеспечивает полный перебор всех возможных сценариев, часть информации отбрасывается и выходные данные получают некорректными.

В данной работе предлагается подход к генерации и ранжированию, призванный устранить описанный недостаток. Цель алгоритма — найти к сценариев с наиболее высоким показателем риска без полного перебора всех возможных вариантов. Достигается это следующим образом.

1. В ходе выполнения алгоритма генерации были сформированы пары

техника-уязвимость с вычисленными метриками. Сформированное множество может содержать несколько вариантов пар для одной техники, если она связана с несколькими уязвимостями.

2. Внутри каждой тактики необходимо отсортировать полученные пары таким образом, чтобы выбор первой пары на каждом этапе сценария дал наиболее высокий показатель риска для рассматриваемого сценария. Функция риска сценария (7) представляет собой произведение вероятностей эксплуатации уязвимостей на каждом шаге сценария и суммы ущерба проэксплуатированных уязвимостей, нормированной по сумме максимумов ущерба на каждой тактике. Эта функция нелинейна и не декомпозируется на риск отдельного шага сценария, отсюда возникает проблема выбора подходящей метрики для сортировки. В данном алгоритме в качестве такой метрики выступает показатель риска для отдельной уязвимости, вычисляемый по формуле (6) и позволяющий учесть вклады вероятности эксплуатации и ущерба конкретной CVE в общий риск сценария.

3. Далее из отсортированных списков пар для каждой тактики берётся первая в списке пара (с наибольшим значением риска уязвимости). Полученный сценарий назовём стартовым. Он помещается в приоритетную очередь, где в качестве ключа приоритета используется риск сценария, и помечается для алгоритма как уже рассмотренный. Затем происходит расширение стартового сценария: поочерёдно на каждой тактике пара техника-уязвимость заменяется на следующую в списке (соответственно, с меньшим значением риска уязвимости) при сохранении остальных пар теми же. Рассмотрим пример: пусть в изначальном множестве имеется 5 тактик, для каждой тактики i есть некоторое количество n_i пар техника-уязвимость, проиндексированных от 0 до $(n_i - 1)$. Если стартовый сценарий S_0 можно представить в виде вектора

$$S_0 = (0,0,0,0,0), \quad (11)$$

то следующие сценарии будут выглядеть следующим образом:

$$S_1 = (1,0,0,0,0), \quad (12)$$

$$S_2 = (0,1,0,0,0) \quad (13)$$

По описанному алгоритму формируются новые сценарии и также помещаются в очередь при условии, что сформированный сценарий не был добавлен в очередь ранее. Пока очередь не пуста, из неё извлекается сценарий с наибольшим рассчитанным риском и добавляется в выдачу. Алгоритм продолжает работу до тех пор, пока не будет сгенерировано заданное количество линейных сценариев, и обеспечивает генерацию сценариев с наибольшим показателем риска за приемлемое время.

Визуализация сгенерированных сценариев и результатов анализа рисков

Сформированное множество сценариев передаётся от серверной части программного комплекса клиентской части, в качестве которой способен работать любой современный браузер. Пользовательский интерфейс разработанного программного модуля позволяет отобразить всё множество возможных сценариев атаки на выбранный защищаемый объект в виде, представленном на рис. 3 и 4.

Узлы тактик данного множества сценариев обозначены как T, узлы уязвимостей — CVE. Тактики сгруппированы по техникам, что тоже визуально отражено на представленном изображении. Узлы «Начало» и «Конец» обозначают начало и конец сценария реализации атаки соответственно. Все узлы визуализированного множества сценариев интерактивны и могут быть перемещены пользователем в любое удобное место холста.

Кроме этого, для визуализации реализованы функции масштабирования изображения без потери качества и выгрузки в форматах PNG и SVG. Интерактивность подразумевает не только возможность перемещать узлы в рамках холста визуализации, но и даёт возможность получать информацию о названии (идентификаторе) конкретного узла при

наведении на него курсора мыши. При клике по любому из визуализированных узлов множества сценариев возможно открыть боковую панель с подробной информацией о выбранном компоненте, что продемонстрировано на рис. 5.

Тонирование узлов представленного множества сценариев позволяет наглядно увидеть наиболее опасные и вероятные пути из всех возможных. Цвет узла CVE зависит от исходного вектора CVSS уязвимости, а тонирование соединяющих линий определяется значением нормированной вероятности уязвимости в полной группе событий, рассчитываемой по формуле (2).

Рассмотрим множество сценариев атак, релевантных для консольного сервера Digi ConnectPort LTS 32 MEI (cpe:2.3:h:digi:connectport_lts_32_mei:-:*:*:*:*:*:*) (рис. 6). Линейные сценарии атак на выбранный объект защиты могут быть визуализированы двумя способами: на холсте в виде последовательности узлов графа, аналогично визуализации множества сценариев атак (рис. 7), либо выбранный сценарий может быть выделен на визуализированном множестве (рис. 8).

На рис. 7 и 8 продемонстрирован один и тот же сценарий из множества, изображённого на рис. 6, с наибольшим показателем риска. В случае выделения сценария на множестве (рис. 8) благодаря тонированию узлов сценария наглядно видно, что выбранный сценарий включает в себя самые критичные уязвимости из представленного множества. Таким образом, тонирование позволяет визуально определить наиболее опасные пути развития атаки до полноценного риск-анализа сформированных сценариев. Сгенерированные линейные сценарии, их описание и оценка риска расположены в правой части веб-интерфейса разработанного приложения (рис. 9):

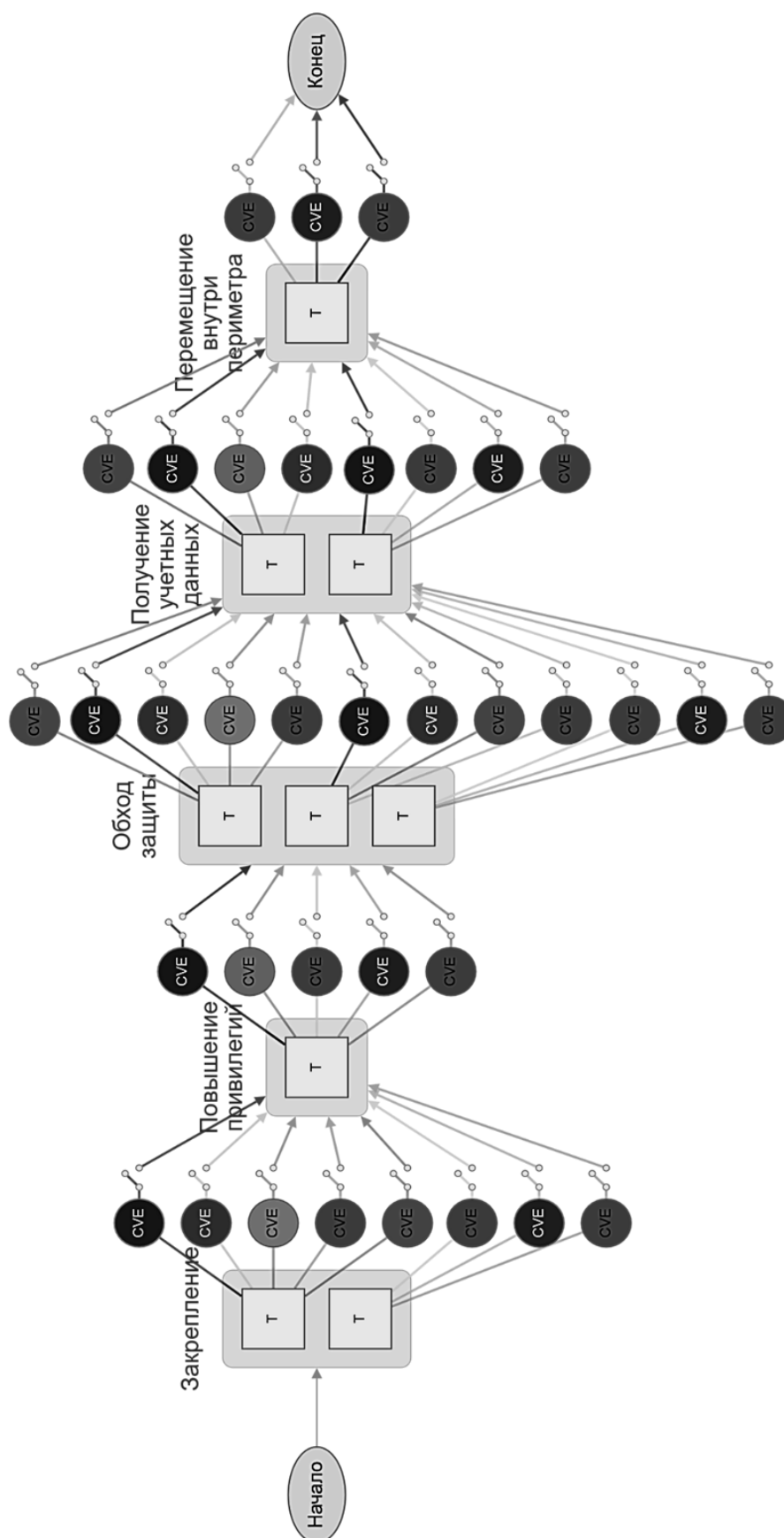


Рис. 4. Множество сценариев атаки на приложение Zoom для операционных систем семейства Linux
(cpe:2.3:a:zoom:zoom:*:*:*:*:linux:*:*)

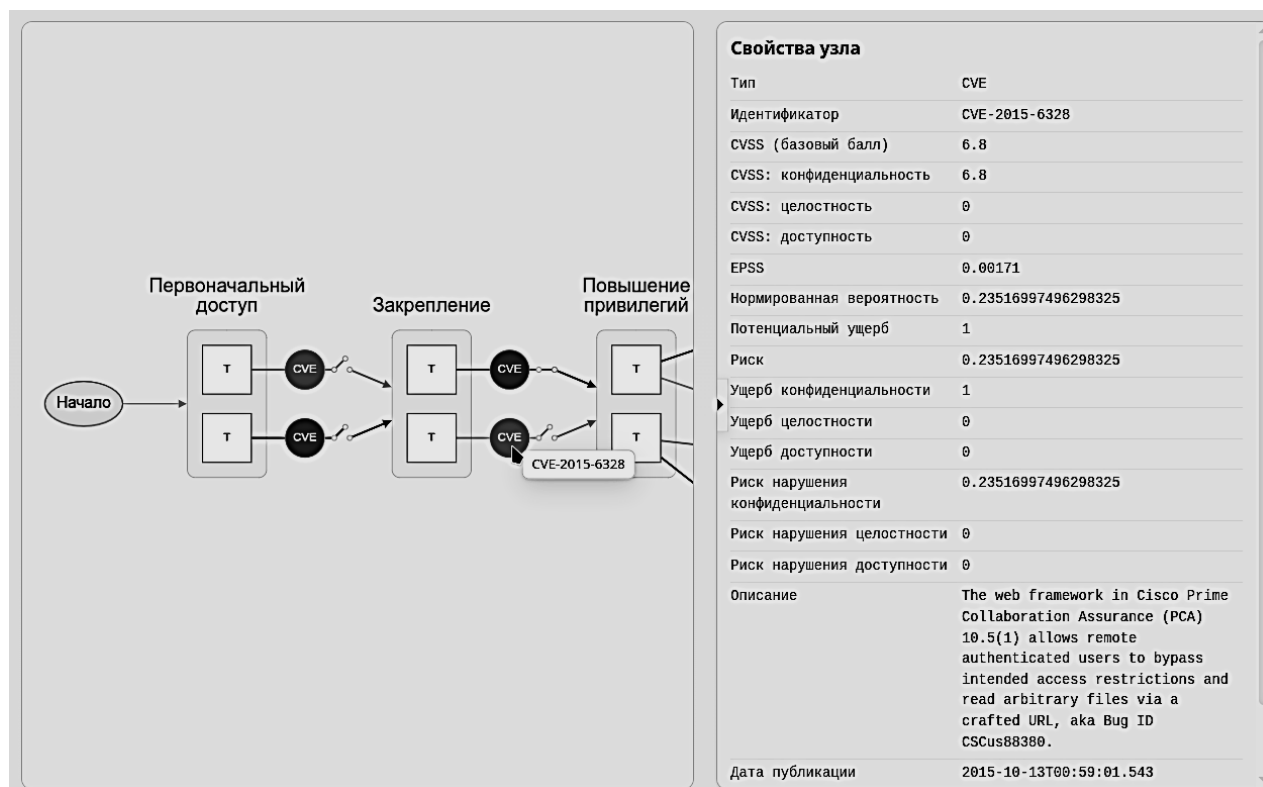


Рис. 5. Боковая панель с подробной информацией о выбранной уязвимости

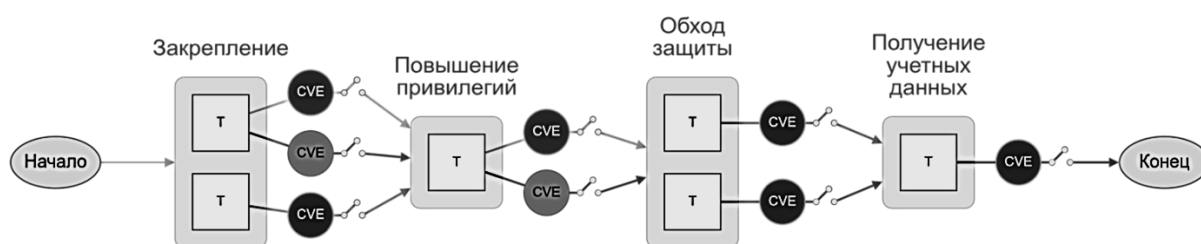


Рис. 6. Множество сценариев атаки на сервер Digi ConnectPort LTS 32 MEI



Рис. 7. Один из множества сценариев атаки на сервер Digi ConnectPort LTS 32 MEI (отдельная визуализация)

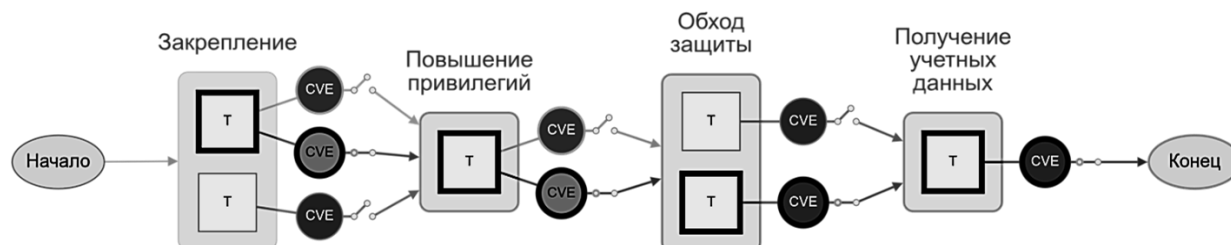


Рис. 8. Один из множества сценариев атаки на консольный сервер Digi ConnectPort LTS 32 MEI (выделенный на множестве)

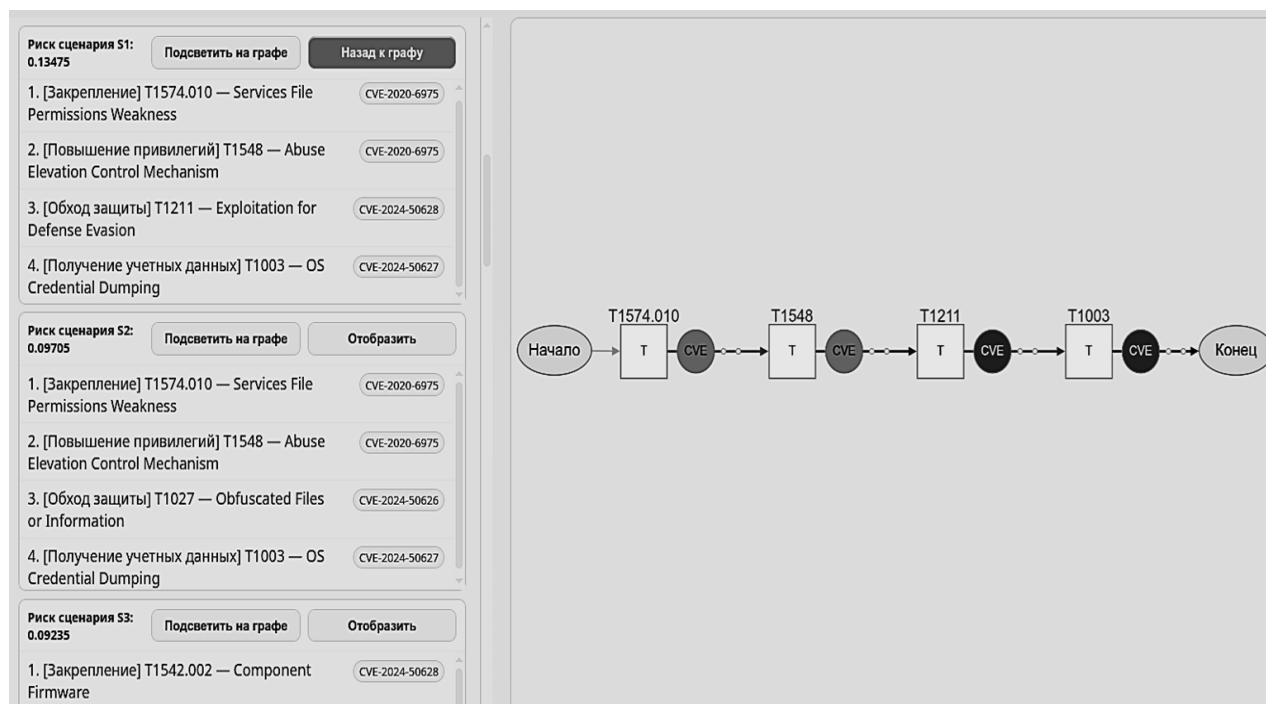


Рис. 9. Описание и оценка риска сгенерированных сценариев атаки на консольный сервер Digi ConnectPort LTS 32 MEI

Ещё одним полезным инструментом для проведения риск-анализа и принятия аналитических решений по управлению рисками является ландшафт множества сформированных сценариев, который может быть получен введением третьего измерения на плоскости, где расположены уязвимости и соответствующие им тактики по осям x и y соответственно. В полученную трёхмерную модель становится возможно вписать всё множество полученных сценариев, но, в отличие от представления данного множества на плоскости (рис. 3, 4, 6), в данном случае мы имеем гораздо более наглядную модель, способную быть более полезной исследователям и специалистам по кибербезопасности в определённых случаях. В качестве метрики по оси z возможно выбрать вероятность эксплуатации уязвимостей, их ущерб либо показатель риска. Также в качестве данной метрики могут выступать показатели риска и ущерба относительно свойств безопасности

информации, вычисленные с использованием расщеплённого показателя CVSS.

Далее на рис. 10 продемонстрируем визуализацию ландшафта множества сценариев для рассмотренного ранее (рис. 4) объекта
 сре:2.3:a:zoom:zoom:*:*:*:*:linux:*:*,
 представляющего собой приложение Zoom для операционных систем семейства Linux, где в качестве метрики выбрана вероятность эксплуатации уязвимостей.

Продemonстрированная модель полностью интерактивна, поддерживает масштабирование, вращение трёхмерного графика во всех плоскостях, а также даёт возможность просматривать информацию об уязвимости путём наведения курсора мыши на соответствующий ей столбец.

Приведём также ландшафт для того же защищаемого объекта, но в качестве метрики для оси z выберем ущерб относительно конфиденциальности (рис. 11).

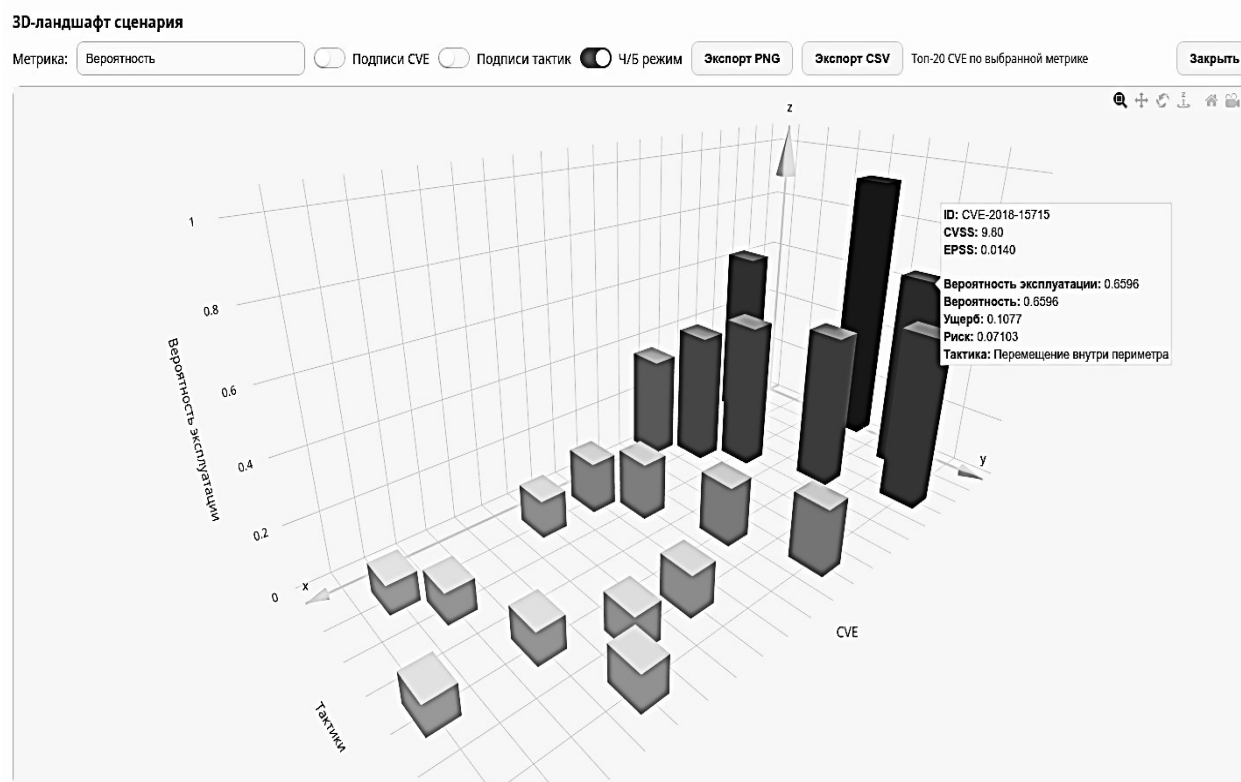


Рис. 10. Ландшафт множества сценариев атак на приложение Zoom для операционных систем семейства Linux (вероятность по оси z)

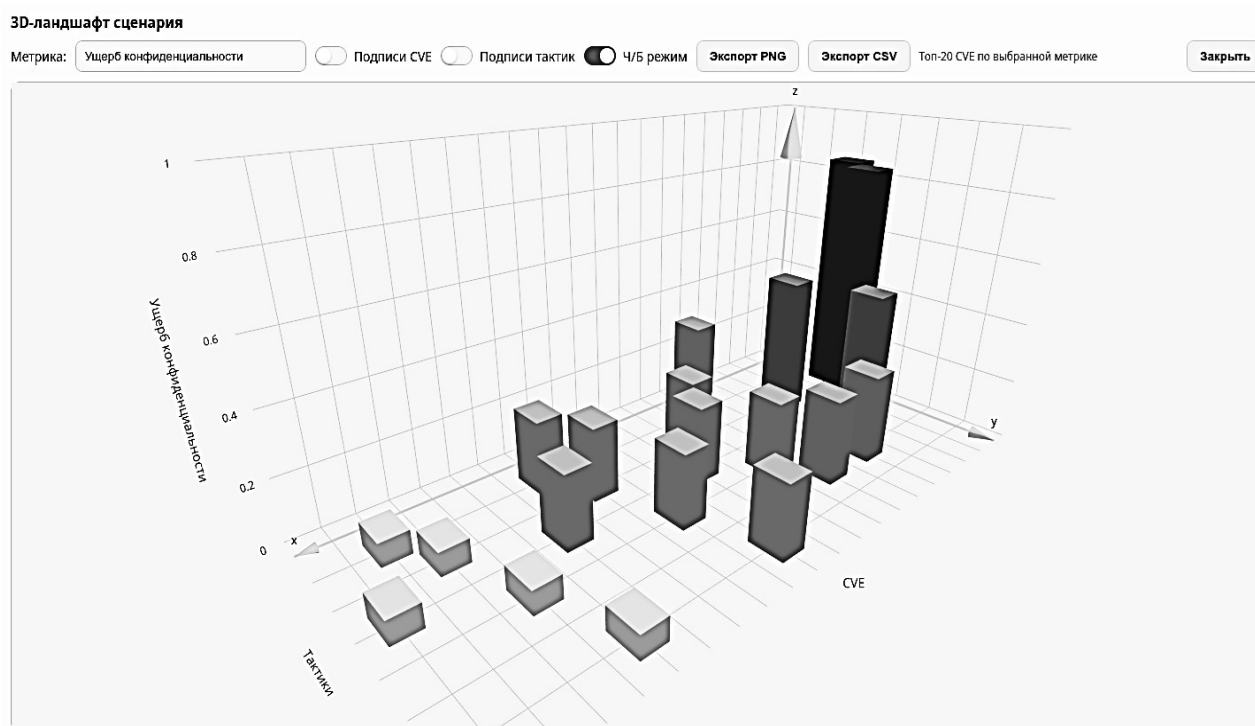


Рис. 11. Ландшафт множества сценариев атак на приложение Zoom для операционных систем семейства Linux (ущерб конфиденциальности по оси z)

На рис. 11 можно сразу выделить две уязвимости, эксплуатация которых приведёт к наибольшему ущербу для конфиденциальности информации. Таким образом, трёхмерный ландшафт множества сценариев оказывается весьма полезен в ситуации, когда необходимо выделить наиболее опасные уязвимости с точки зрения определённой метрики.

Заключение

В результате проведённой работы была разработана и представлена методика генерации и визуализации сценариев компьютерных атак, направленных на защищаемые объекты АИС, и предложена программная реализация разработанной методики и описанных в работе подходов. Разработаны алгоритмы генерации, риск-анализа и ранжирования сценариев атак. Рассмотрены функции и приведены примеры использования разработанного программного комплекса, обеспечивающего агрегацию данных из гетерогенных источников в единую базу знаний, поддержание её в актуальном состоянии, генерацию, риск-анализ, визуализацию сценариев компьютерных атак.

Реализованный программный модуль генерации и визуализации сценариев компьютерных атак на компоненты защищаемых АИС (далее — защищаемые объекты) предлагает пользователю программного обеспечения возможность генерации сценариев реализации компьютерных атак на защищаемые объекты с вариативностью развития событий, приближенной к реальной многошаговой компьютерной атаке. Помимо этого, предлагается визуализация сформированных сценариев в нескольких вариантах и экспорт в различных форматах. Риск-анализ сформированных сценариев позволяет обеспечить их ранжирование в соответствии с показателем риска для наглядного представления наиболее опасных из них.

Модуль генерации сценариев позволяет учитывать как известные взаимосвязи между компонентами кибератак, представленные в базах знаний [6-9], так и отсутствующие в открытых источниках, но при этом весьма вероятные, для чего используются

механизмы GNN. Решение об использовании результатов работы GNN для генерации сценариев принимает непосредственно инженер по защите информации — пользователь программного комплекса. Модуль GNN позволяет расширить множество компонентов кибератак, рассматриваемых в контексте атаки на конкретный объект защиты, тем самым давая возможность включить в рассмотрение и риск-анализ большее количество уязвимостей защищаемого объекта.

Интеграция как с открытыми, так и с коммерческими отечественными сканерами уязвимостей представляется особенно важной с практической точки зрения, позволяя инженерам по защите информации и другим пользователям разработанного программного комплекса производить анализ рисков в отношении любого объекта АИС, для которого были обнаружены уязвимости в ходе сканирования. Программный модуль адаптирован к работе на автоматизированных рабочих местах, может быть развёрнут и подготовлен к использованию в короткие сроки с использованием технологий контейнеризации и предлагается к использованию исследователями в области информационной безопасности, практикующими специалистами и студентами соответствующих специальностей.

Настоящая работа вносит вклад в дальнейшие исследования в данном направлении, которые могут заключаться в более глубокой интеграции GNN в программный модуль для повышения точности предсказания новых связей и обработки большего числа типов узлов графа, использовании более продвинутых моделей GNN, расширении интеграции с существующими отечественными решениями в области ИБ, улучшении и предложении новых методов анализа риска генерируемых сценариев компьютерных атак.

Список литературы

1. Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин, Н.Н. Корвяков, А.А. Ноздрюхин. Формализация знаний и данных кибератак и уязвимостей // //

Информация и безопасность. 2024. Т. 27. Вып. 2. С. 231–238.

2. В.П. Лось, Р.С. Лопатин, Е.С. Петрова, Д.А. Щеглова, А.М. Лебедев, Д.С. Покудин. Моделирования сценариев атак классов «Переполнение буфера» и «Злоупотребление привилегиями» в корпоративной сети // Информация и безопасность. 2025. Т. 28. Вып. 3. С. 321–340.

3. Остапенко Г. А., Остапенко А. А., Кондратьев М. В., Кривошеин А. С., Печкин Д. С. Автоматизация оценки и регулирования рисков реализации кибератак: мотивация и целеполагание создания программно-технического комплекса // Информация и безопасность. 2025. Т. 28. Вып. 3. С. 341–356.

4. Остапенко Г. А., Остапенко А. А., Кондратьев М. В., Кривошеин А. С., Макаров Ю. В. Автоматизация оценки и регулирования рисков реализации кибератак: процедуры сбора, обработки и хранения данных // Информация и безопасность. 2025. Т. 28. Вып. 3. С. 367–388.

5. Остапенко Г. А., Остапенко А. А., Кондратьев М. В., Кривошеин А. С., Неменуций М. Д. Автоматизация оценки и регулирования рисков реализации кибератак: процедуры генерации сценариев // Информация и безопасность. 2025. Т. 28. Вып. 3. С. 397–408.

6. MITRE ATT&CK Framework : официальный сайт. URL: <https://attack.mitre.org/> (дата обращения 15.11.2025).

7. CAPEC – Common Attack Pattern Enumeration and Classification : официальный сайт. URL: <https://capec.mitre.org/> (дата обращения 15.11.2025).

8. CWE – Common Weakness Enumeration : официальный сайт. URL: <https://cwe.mitre.org/> (дата обращения 15.11.2025).

9. NVD – National Vulnerability Database : официальный сайт. URL: <https://nvd.nist.gov/> (дата обращения 15.11.2025).

10. CISA – Cybersecurity and Infrastructure Security Agency: официальный сайт. URL: <https://www.cisa.gov/> (дата обращения 15.11.2025).

11. FIRST – Forum of Incident Response and Security Teams : официальный сайт. URL: <https://www.first.org/> (дата обращения 15.11.2025).

12. Neo4j: официальный сайт. URL: <https://neo4j.com/> (дата обращения 15.11.2025).

13. Practical Guide to Common Platform Enumeration (CPE) // FOSSA Blog. URL: <https://fossa.com/blog/practical-guide-common-platform-enumeration-cpe/> (дата обращения 15.11.2025).

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 20.11.2025

Информация об авторах

Остапенко Александр Алексеевич – аспирант, Воронежский государственный технический университет, e-mail: alexostap123@gmail.com.

Краснопольский Сергей Викторович – студент, Воронежский государственный технический университет, e-mail: krasnopolskiy.02@mail.ru

Скрипкин Максим Михайлович – студент, Воронежский государственный технический университет, e-mail: scripkin.maks2017@yandex.ru

Яснев Александр Владимирович – студент, Воронежский государственный технический университет, e-mail: shura.t9@mail.ru

THE METHODOLOGY OF AUTOMATED PROCESSING OF MEASURES TO COUNTER CYBER ATTACKS AND RECALCULATION OF RISK, TAKING INTO ACCOUNT THEIR EFFECTIVENESS

A.A. Ostapenko, S.V. Krasnopolsky, M.M. Skripkin, A.V. Yasenev

The article discusses an approach to generating and visualizing scenarios of computer attacks on protected objects that are components of automated information systems, and suggests a software implementation of this approach. The approach provides a methodology for implementing simulation scenarios for exploiting vulnerabilities in relation to protected objects to counter modern computer attacks. The relevance of the information received at the input of the software module is ensured by using aggregated data from the MITRE ATT&CK, CAPEC, CWE, NVD, EPSS and CISA KEV knowledge bases. An algorithm for generating computer attack scenarios and an algorithm for ranking them is proposed, which solves the problem of "combinatorial explosion" and allows selecting scenarios with the highest risk index with an acceptable hardware load.

Keywords: generation, modeling, scenario, vulnerabilities, attack patterns, tactics, techniques, computer attacks.

Submitted 20.11.2025

Information about the authors

Alexander A. Ostapenko – graduate student, Voronezh State Technical University, e-mail: alexostap123@gmail.com

Sergey V. Krasnopolsky – student, Voronezh State Technical University, e-mail: krasnopolskiy.02@mail.ru

Maxim M. Skripkin – student, Voronezh State Technical University, e-mail: scripkin.maks2017@yandex.ru

Alexander V. Yasenev – student, Voronezh State Technical University, e-mail: shura.t9@mail.ru